



LIANGSHAN ENTERPRISE

ENTERPRISE INFORMATION SECURITY POLICY

Date: 19th Nov, 2024

Submitted to: M. Abdullah Abid



iv. Enterprise Information Security Policy (EISP)

1. Purpose

The purpose of this policy is to establish a comprehensive framework for safeguarding the confidentiality, integrity, and availability of Liangshan Enterprise's information assets. This policy aligns with industry standards and regulations such as ISO 27001, GDPR, and China's Cybersecurity Law, ensuring robust protection of organizational data and resources.

2. Authority

The EISP is authorized and governed by the Chief Information Officer (CIO) of Liangshan Enterprise, in collaboration with the Chief Information Security Officer (CISO), and has been approved by the Board of Directors. All employees, contractors, and third parties are required to adhere to the policies outlined in this document.

3. Scope

This policy applies to:

- All Liangshan Enterprise employees, contractors, consultants, & third-party vendors.
- All information systems, devices, and assets (physical and digital) owned, managed, or leased by the enterprise.
- All business units, global offices, data centers, and remote workstations.

4. Responsibility

- **Executive Team:** Ensures enterprise-wide compliance with this policy.
- **CISO and IT Department:** Develops, maintains, and enforces security policies, standards, and procedures.
- **Employees and Third Parties:** Must adhere to the security guidelines outlined and report any violations or incidents promptly.
- **Security Operations Center (SOC):** Monitors systems, detects anomalies, and responds to incidents.

5. Compliance

Liangshan Enterprise must comply with:

- ISO 27001 standards for information security management.
- Data privacy regulations such as GDPR, CCPA, and China's Cybersecurity Law.

- Contractual obligations with clients and partners.

Failure to comply may result in disciplinary action, contractual penalties, or legal repercussions.

6. Information Security Objectives

- Protect the confidentiality, integrity, and availability of information assets.
- Minimize risks from internal and external threats, ensuring business continuity.
- Promote security awareness and a culture of accountability among employees.
- Achieve and maintain compliance with international and local regulations.

7. Communications

- **Internal Communications:** The CISO will disseminate updates and guidelines via official communication channels (email, intranet, and training sessions).
- **External Communications:** Information regarding security measures will be shared with clients and vendors as necessary to ensure mutual compliance

8. Reporting Requirements

8.1 Policy Violations

Any violations of this policy must be reported to the IT department immediately.

8.2 Reporting of Policy Violations

Employees must report incidents such as unauthorized access, data breaches, or policy violations using the official incident reporting form.

8.3 Exceptions from Policy

Any exceptions to this policy must be approved by the CISO in collaboration with the CIO and documented for auditing purposes.

9. Policy

9.1 Organization of Information Security

Each department at Liangshan Enterprise is required to establish and maintain comprehensive information security policies, standards, guidelines, and procedures (PSGPs) to protect information assets while ensuring alignment with business objectives.

- **Information Security Structure:** A centralized Security Operations Center (SOC) operates 24/7, providing real-time monitoring, incident management, and policy enforcement.

- **Roles and Responsibilities:** Responsibilities are distributed among the executive team (CIO and CISO), departmental heads, and operational teams to ensure accountability for security.
- **Policy Life Cycle Management:** Policies undergo annual reviews and updates based on regulatory changes, audits, and identified risks.
- **Awareness Programs:** Employees undergo mandatory training on new policies and periodic refreshers to maintain compliance.

9.2 Acceptable Use Policy

9.2.1 General Use and Ownership

- **Liangshan Proprietary Information**

Liangshan Enterprise's proprietary information, including sensitive data such as architectural designs, client contracts, and Building Information Models (BIM), is the cornerstone of its operations. To ensure customer privacy and uphold the company's reputation, Liangshan enforces protection measures aligned with international standards, including ISO 27001. Proprietary information is managed securely and responsibly.

- **Prompt Reporting of Theft, Loss, or Unauthorized Disclosure**

Liangshan's Security Operations Center (SOC) actively monitors and responds to security incidents. Employees are required to report any incidents involving theft, loss, or unauthorized disclosure of proprietary information immediately. This proactive approach is vital to maintaining operational integrity and data security.

- **Access, Use, or Sharing of Proprietary Information**

Access to proprietary information is restricted to authorized personnel based on the principle of least privilege. Employees may only access information necessary to fulfill their roles, ensuring a balance between operational efficiency and data security. Unauthorized sharing or misuse of proprietary information is strictly prohibited.

- **Exercise of Good Judgment for Personal Use**

Employees are encouraged to exercise good judgment when using company resources for personal purposes. Personal use must not interfere with business operations or compromise the security of company assets.

- **Monitoring by Authorized Individuals**

Liangshan's SOC, operating 24/7, ensures the security of company systems. Authorized personnel are permitted to monitor equipment, systems, and network traffic to address potential threats and maintain system integrity.

- **Right to Audit Networks and Systems**

Liangshan retains the right to audit its networks and systems periodically. These audits ensure compliance with security policies, enhance transparency, and uphold accountability in all security practices.

9.2.2 Security and Proprietary Information

- **Compliance with Minimum Access Policy**

All mobile and computing devices connecting to Liangshan's internal network must adhere to the Minimum Access Policy. This policy ensures a secure and unified access control framework across the organization.

- **Password Policy**

Liangshan emphasizes the importance of secure credentials. All passwords must comply with the company's Password Construction Guidelines, ensuring robust protection for systems and accounts.

- **Password-Protected Lock Screens**

All devices must employ password-protected lock screens with automatic activation after a specified period of inactivity. This measure prevents unauthorized access and aligns with best practices in device security.

- **Disclaimer in Postings from Liangshan Email Address**

Employees posting to newsgroups or online platforms using a Liangshan email address must include a disclaimer distinguishing personal opinions from official company statements. This practice ensures responsible and transparent communication.

- **Caution in Opening Email Attachments**

To mitigate risks of malware, employees must exercise caution when opening email attachments. Email security protocols must be followed rigorously to protect the integrity of company data.

9.2.3 Unacceptable Use

- **System and Network Activities**

Prohibited activities include unauthorized access, security breaches, introducing malicious programs, or engaging in activities that could harm the integrity of Liangshan's systems. These restrictions ensure the company operates within legal and ethical boundaries.

- **Email and Communication Activities**

Employees are prohibited from sending unsolicited emails, engaging in harassment, or using company resources for non-business-related activities. These policies reinforce Liangshan's commitment to maintaining a secure and respectful working environment.

- **Blogging and Social Media**

Employees are encouraged to engage with communities responsibly. Blogging or social media activities must not compromise Liangshan's interests. Posts should align with the company's ethical standards and values, ensuring consistency with the organization's commitment to professionalism.

9.3 Email Policy

9.3.1 Consistency with Policies and Ethical Conduct

Liangshan Enterprise ensures that all email communications align with its policies, ethical guidelines, and safety protocols. Employees must adhere to relevant laws and business practices, ensuring that email behavior reflects the company's values and legal obligations.

9.3.2 Primary Use for Business Purposes

Liangshan email accounts are the primary means of communication for official business-related activities. Limited personal use is allowed, provided it does not interfere with work or compromise the company's systems. Employees are prohibited from engaging in non-Liangshan-related commercial activities through company email.

9.3.3 Data Protection Standard

All email communications must comply with Liangshan's Data Protection Standards, ensuring the confidentiality and integrity of sensitive information. Employees are responsible for safeguarding proprietary data shared via email and adhering to encryption requirements when necessary.

9.3.4 Retention of Business Records

Emails classified as business records must be retained per Liangshan's Record Retention Schedule. These records must have a legitimate and ongoing business purpose. Non-critical emails should not be retained unnecessarily to minimize data storage risks and costs.

9.3.5 Prohibition of Disruptive or Offensive Messages

Liangshan prohibits the use of its email system for creating or distributing disruptive or offensive messages. Content that may be offensive based on race, gender, religion, or other protected characteristics is strictly forbidden. Employees encountering such messages must report them promptly to the Human Resources or IT department.

9.3.6 Prohibition of Automatic Forwarding

To protect sensitive data, automatic forwarding of Liangshan emails to external third-party systems is not allowed. Manual forwarding must exclude any confidential or proprietary information unless explicitly authorized.

9.3.7 Reasonable Personal Use

Employees may use the company's email system for personal communication within reasonable limits, ensuring it does not disrupt business operations. Sending chain letters, joke emails, or any similar content is prohibited to maintain professionalism and reduce unnecessary email traffic.

9.3.8 No Expectation of Privacy

Employees should have no expectation of privacy when using Liangshan's email system. All communications are subject to monitoring to ensure compliance with company policies and security standards.

9.3.9 Monitoring and Notice

Liangshan reserves the right to monitor all email communications without prior notice. This measure ensures the integrity of the email system and prevents misuse. Employees are reminded to use the email system responsibly and securely.

9.4 Server Security Policy

9.4.1 General Requirements

- **Server Ownership and Configuration:**
 - All internal servers must be owned by designated operational groups responsible for their system administration.

- The Information Security (InfoSec) team must establish, maintain, and review approved server configuration guides based on the business needs of Liangshan Enterprise.
- Servers must be registered in the corporate enterprise management system, which must include essential information such as:
 - Contact details of responsible personnel.
 - Hardware specifications.
 - Operating system and version details.
 - Server functions and hosted applications.
- The enterprise management system must be kept up to date to reflect changes in server configurations or ownership.
- Configuration changes for production servers must adhere to established change management procedures.
- **Monitoring and Auditing:**
 - Authorized personnel may monitor and audit equipment, systems, processes, and network traffic for security, compliance, and maintenance purposes, following Liangshan's Audit Policy.

9.4.2 Configuration Requirements

- **Operating System Configuration:**
 - All server operating system configurations must align with the guidelines established by the InfoSec team to ensure consistent security and operational integrity.
- **Services and Applications:**
 - Disable all unused services and applications to minimize security risks and reduce the attack surface.
- **Access Control and Logging:**
 - Log and secure access to services using tools like a web application firewall (WAF).
 - Install the latest security patches promptly unless exceptions are documented for business-critical reasons.
 - Avoid trust relationships between systems, as they introduce unnecessary security vulnerabilities.
 - Apply standard security principles, including granting only the minimum level of access necessary for operational needs.
 - Privileged access to servers must be conducted over secure channels, such as encrypted network connections (e.g., SSH or IPsec).

- Servers must be physically located in access-controlled, secured environments. Server operation from uncontrolled or unsecured cubicle areas is strictly prohibited.

9.4.3 Monitoring

- **Security-Related Event Logging:**
 - Log all security-related events on critical or sensitive systems to ensure traceability and accountability.
- **Retention requirements for logs:**
 - **Online Logs:** Retain for a minimum of 1 week.
 - **Daily Incremental Tape Backups:** Retain for at least 1 month.
 - **Weekly Full Tape Backups:** Retain for at least 1 month.
 - **Monthly Full Backups:** Retain for a minimum of 2 years.
- **Incident Reporting:**
 - Security-related events must be reported to the InfoSec team for review and further escalation to IT management as required.
 - Examples of security-related events include:
 - Port-scan attacks.
 - Evidence of unauthorized access to privileged accounts.
 - Anomalous activities that deviate from normal operations.

9.5. Data Breach Response Policy for Liangshan Enterprise

9.5.1 Incident Identification and Response Team Formation

- **Identification and Immediate Action:**
 - Upon detecting a theft, breach, or exposure of Liangshan Enterprise's Protected or Sensitive Data, access to the affected resources must be immediately removed.
 - The Security Operations Center (SOC) will initiate containment procedures to isolate compromised systems.
- **Response Team Formation:**
 - The Executive Director will lead an Incident Response Team (IRT) to manage and mitigate the breach. The team will include representatives from:
 - IT Infrastructure
 - IT Applications
 - Legal and Compliance
 - Finance

- Communications
- Human Resources
- Member Services
- The affected unit or department
- Additional departments and subject matter experts may be involved based on the data type or systems impacted.

9.5.2 Notification and Analysis

- **Incident Notification:**
 - The Executive Director and key stakeholders will be notified of the breach immediately after initial identification.
 - Relevant regulatory bodies, impacted clients, and third-party partners will be informed as required by data protection laws (e.g., GDPR mandates notification within 72 hours of breach discovery).
- **Forensic Analysis:**
 - IT personnel, in collaboration with external forensic investigators (where necessary), will analyze the breach to determine:
 - The root cause of the incident.
 - The method of attack or unauthorized access.
 - The types of data involved (e.g., client information, architectural designs, financial records).
 - The impact on affected individuals, systems, and operations.
 - The findings will guide containment and remediation strategies.

9.5.3 Containment and Eradication

- **Containment:**
 - The SOC will implement immediate containment measures, such as isolating affected systems, disabling compromised accounts, and blocking malicious IPs.
 - Backup data will be accessed to ensure continued business operations while addressing the breach.
- **Eradication:**
 - Malware and unauthorized software will be removed from compromised systems.
 - Vulnerabilities exploited during the breach will be patched, and all systems will undergo rigorous security checks.

9.5.4 Recovery and Restoration

- **System Restoration:**
 - Data and services will be restored from secure backups once the breach is fully contained and risks mitigated.
 - Systems will be monitored for anomalies during the recovery process to prevent further compromise.
- **Communication:**
 - The Communications team will issue updates to internal stakeholders, clients, and regulatory authorities throughout the recovery process.
 - Clear communication ensures transparency and maintains trust with affected parties.

9.5.5 Post-Incident Review

- **Incident Documentation:**
 - A detailed incident report will be prepared, documenting:
 - Timeline of events.
 - Root cause analysis.
 - Actions taken for containment, eradication, and recovery.
 - Lessons learned and recommended preventive measures.
- **Policy and Procedure Updates:**
 - The IRT will review and update existing security policies and procedures based on findings from the breach.
 - Additional training for employees and IT personnel will be conducted to prevent similar incidents.

9.5.6 Preventive Measures

- **Proactive Monitoring:**
 - SOC will enhance real-time monitoring capabilities using advanced intrusion detection systems (IDS) and Security Information and Event Management (SIEM) tools.
- **Regular Security Assessments:**
 - Periodic penetration tests and vulnerability assessments will be conducted to identify potential security gaps.
- **Employee Training:**
 - All employees will undergo mandatory training on identifying phishing attempts, managing sensitive data, and reporting suspicious activities.

9.5.7 Regulatory Compliance

- **Legal and Regulatory Adherence:**
 - Liangshan will adhere to all applicable regulations (e.g., GDPR, CCPA, and China's Cybersecurity Law) regarding data breach notification and response.
 - The Legal and Compliance team will ensure that all actions align with these laws to avoid penalties and maintain trust.

9.5.8 Cyber Insurance Utilization

- Liangshan will leverage its cyber insurance policy for:
 - Engaging professional forensic investigators.
 - Covering costs associated with breach containment, notification, and legal compliance.
 - Mitigating financial impacts from data breaches.

9.6 Password Construction Policy

9.6.1 Password Strength Recommendations

- **Mandatory Strong Passwords:**
 - All employees must create strong passwords to secure access to company systems, data, and applications.
 - Passwords must meet the following criteria:
 - **A minimum of 16 characters.**
 - Inclusion of a mix of upper- and lower-case letters, numbers, and special characters.
 - Avoid using easily guessable information such as birthdays, usernames, or common words.
- **Prohibited Practices:**
 - Reuse of previous passwords is not allowed.
 - Sharing passwords with colleagues or external parties is strictly forbidden.

9.6.2 Use of Passphrases

- **Passphrase Recommendation:**
 - Employees are encouraged to use **passphrases** as an alternative to traditional passwords. These are longer combinations of multiple unrelated words, making them more secure and easier to remember.
 - Passphrases must still adhere to the minimum strength requirements, with at least 16 characters.

- **Examples of Strong Passphrases:**
 - *"It's time for vacation."*
 - *"block-curious-sunny-leaves."*
 - Passphrases may include spaces for improved readability.
- **Prohibited Passphrases:**
 - Avoid passphrases with dictionary words in predictable combinations (e.g., "1234password" or "password2024").

9.6.3 Periodic Password Cracking or Guessing

- **Password Security Assessments:**
 - The Information Security (InfoSec) Team or authorized personnel will conduct periodic and random password cracking or guessing tests to evaluate system security.
 - These scans will identify weak, easily guessable, or reused passwords across company systems.
- **Action on Cracked Passwords:**
 - If a password is guessed or cracked during assessments, the affected user must:
 - Change their password immediately to meet strength requirements.
 - Review Liangshan's Password Construction Guidelines to prevent future vulnerabilities.

9.6.4 Password Storage and Protection

- **Encryption of Passwords:**
 - All passwords must be securely stored using industry-standard encryption algorithms (e.g., SHA-256 with salting).
- **Credential Vaults:**
 - Employees managing multiple accounts or administrative privileges are encouraged to use a secure password manager or credential vault.
- **Lock Screen Requirements:**
 - All computing devices must have password-protected lock screens that activate after a maximum of five minutes of inactivity.

9.6.5 Password Change Requirements

- **Password Update Triggers:**
 - Password changes are required:
 - After a suspected or confirmed compromise.
 - When an employee transitions roles requiring elevated access.

- **Avoid Frequent Changes:**
 - Regular expiration of passwords is discouraged unless a compromise is suspected, as frequent changes may lead to weaker, less secure passwords.

9.6.6 User Training and Awareness

- **Employee Training:**
 - Employees will undergo regular training sessions to:
 - Understand the importance of secure passwords.
 - Recognize phishing attempts aimed at obtaining passwords.
 - Training will emphasize the benefits of using passphrases over shorter, complex passwords.
- **Ongoing Awareness Campaigns:**
 - The InfoSec Team will periodically share updates and reminders about best practices in password management.

9.6.7 Compliance Monitoring

- **Audit and Enforcement:**
 - The InfoSec Team will routinely audit password compliance across all systems.
 - Employees found using non-compliant passwords will be required to update them immediately.

9.7 Employee Internet Use Monitoring and Filtering Policy

9.7.1 Web Site Monitoring

- **Responsibility:**
 - The IT Department at Liangshan Enterprise is responsible for continuous monitoring of Internet use across all devices and systems connected to the corporate network.
- **Monitoring System:**
 - The monitoring system will log critical details for all network traffic, including:
 - Source IP Address
 - Date and time of access
 - Protocol used
 - Destination site or server
 - User ID associated with the traffic.

- **Data Retention:**

- Internet use records will be preserved for **180 days** to ensure compliance with legal, regulatory, and security requirements.

9.7.2 Internet Use Filtering System

- **Deployment:**

The IT Department will implement a robust filtering system to block access to inappropriate or non-business-related websites and protocols.

- **Categories of Websites Blocked:**

- Adult/Sexually Explicit Material
- Advertisements & Pop-Ups
- Chat and Instant Messaging
- Gambling
- Hacking
- Illegal Drugs
- Intimate Apparel and Swimwear
- Peer-to-Peer File Sharing
- Personals and Dating
- Social Network Services
- SPAM, Phishing, and Fraud
- Spyware
- Tasteless and Offensive Content
- Violence, Intolerance, and Hate
- Web-Based Email (unless explicitly approved)

- **Objective:**

- To create a secure, professional, and productive work environment that adheres to Liangshan's ethical and legal standards.

9.7.3 Internet Use Filtering Rule Changes

- **Regular Reviews:**

- The IT Department will conduct regular reviews of web and protocol filtering rules to ensure they meet evolving security and business requirements.

- **Recommendations and Approvals:**

- Proposed changes to filtering rules will be submitted to Human Resources (HR) for evaluation.
- HR will approve or reject changes and document all modifications within the Internet Use Monitoring and Filtering Policy.

- **Record-Keeping:**

All changes to filtering rules will be meticulously recorded to maintain transparency and accountability.

9.7.4 Internet Use Filtering Exceptions

- **Requesting Unblocking of Mis-Categorized Sites:**

- Employees can request to unblock a site believed to be mis-categorized by submitting a ticket to the IT Help Desk.
- IT personnel will promptly review and unblock the site if deemed appropriate.

- **Requests for Business-Related Access:**

- Employees requiring access to blocked sites for legitimate business purposes must:
 - Submit a request to their HR representative, detailing the reason for access.
 - HR will evaluate the request and, if approved, notify IT to grant access exclusively to the requesting employee.

- **Exception Records:**

- The IT Department will maintain a detailed log of all approved exceptions, including:
 - Requestor details
 - Justifications for access
 - Categories or sites unblocked.
- Reports on exceptions will be available upon request for auditing or review.

9.7.5 Employee Awareness and Compliance

- **Training:**

- Employees will receive regular training on responsible Internet use, filtering policies, and the procedure for requesting access exceptions.

- **Policy Adherence:**

- Employees found violating the Internet Use Monitoring and Filtering Policy may face disciplinary action, including suspension of Internet access or other penalties as determined by HR.

10. Policy Framework Coverage

Policy Ref#	Policy Name	Topics Covered
IS 001	Organization of Information Security	- Centralized Security Operations Center (SOC) operates 24/7. - Roles and responsibilities for security accountability. - Policy life cycle management with regular updates. - Mandatory awareness programs for employees.
IS 002	Acceptable Use Policy	- General use and ownership of company resources. - Management of proprietary information, including reporting of unauthorized disclosures. - Restrictions on system, network, & communication activities. - Blogging and social media activity guidelines.
IS 003	Email Policy	- Consistency with company policies and ethical guidelines. - Primary use for business purposes with limited personal use. - Data protection and retention of business records. - Prohibition of offensive content and automatic forwarding.
IS 004	Server Security Policy	- Server ownership and configuration management. - Operating system configuration standards & service access control. - Event logging and retention requirements. - Incident reporting for security-related events.
IS 005	Data Breach Response Policy	- Incident identification and formation of a response team. - Notification and forensic analysis of breaches. - Containment, eradication, and recovery protocols. - Preventive measures and adherence to regulatory compliance.
IS 006	Password Construction Policy	- Recommendations for strong passwords and passphrases. - Periodic password cracking and secure storage practices. - Guidelines for password updates and compliance monitoring.
IS 007	Employee Internet Use Monitoring and Filtering Policy	- Website monitoring and data retention requirements. - Deployment of filtering systems for inappropriate websites and protocols. - Rules for filtering exceptions and reporting. - Regular employee training and policy adherence.

Table 4.1 Policy Framework Coverage

11. Document Change Control

No.	Revised By	Effective Date	Change Description
1.0	CIO	03/09/2024	Initial draft of the EISP
1.1	CISO	19/09/2024	Updated compliance section to include CCPA
1.2	IT Department	01/10/2024	Added Logging and Event Monitoring Policy
1.3	CISO	09/10/2024	Updated password policy and MFA requirements
1.4	CIO	28/10/2024	Expanded Asset Management to include mobile and IoT devices
1.5	IT Department	05/10/2024	Revised cryptographic standards for AES-256 encryption
1.6	CIO	20/11/2024	Integrated ISO 27001 guidelines into the compliance framework

Table 4.1 Policy Framework Coverage

11.1 Annual Review

This EISP will be reviewed and updated annually by the CISO, or when significant policy or procedure changes necessitate an amendment. The next review is scheduled for 2025-01-01.

Additionally, document updates are initiated in response to internal and external audits, ensuring continuous improvement and adaptability to evolving security requirements.